

Sistem Manajemen Lab & Skrining Awal Tuberkulosis (TBC)

Laboratory Management System & Initial Screening for Tuberculosis (TB)

COKORDA GD. SATRIA WIDNYANA PUTRA^{1*}, WALID NADIRUL AHNAF², YASIR³

Abstrak

Tuberkulosis (TBC) merupakan penyakit menular yang masih menjadi beban kesehatan global, dengan Indonesia menempati posisi kedua dunia dalam jumlah kasus. Diagnosis histopatologi TBC yang dilakukan secara manual sangat bergantung pada keahlian dokter patologi, sehingga dibutuhkan sistem digital terintegrasi yang tidak hanya mempercepat alur klinis, tetapi juga menjamin keamanan data medis sensitif. Penelitian ini merancang dan mengimplementasikan arsitektur keamanan berlapis pada backend sistem manajemen laboratorium TBC berbasis web dengan pendekatan human-in-the-loop menggunakan Express.js v5, Prisma ORM, dan PostgreSQL. Tujuh mekanisme keamanan diimplementasikan meliputi autentikasi JWT HS256 dengan kebijakan first-login enforcement, enkripsi AES-256-ECB deterministik pada atribut identitas sensitif pasien, kontrol akses berbasis peran, isolasi data antar institusi, audit log append-only, pembatasan laju akses, serta tanda tangan digital berbasis SHA-256 pada laporan klinis. Pengujian melalui delapan skenario ancaman keamanan menunjukkan seluruh mekanisme pertahanan berfungsi sesuai ekspektasi. Overhead performa yang timbul masih dalam batas toleransi, dengan peningkatan waktu respons login 33,0% sebagai konsekuensi terencana dari algoritma Bcrypt. Sistem ini membuktikan bahwa keamanan berlapis dapat diterapkan pada platform medis digital tanpa mengorbankan ketersediaan layanan secara signifikan.

Kata Kunci: Audit log, Autentikasi, Enkripsi, Keamanan, RBAC, Tuberkulosis.

Abstract

Tuberculosis (TB) remains a critical global health burden, with Indonesia ranking second worldwide in case contribution. Manual histopathological diagnosis of TB is heavily dependent on pathologist expertise, necessitating an integrated digital system that ensures both clinical efficiency and security of sensitive medical data. This study designs and implements a layered security architecture for a web-based TB laboratory management system backend using a human-in-the-loop approach with Express.js v5, Prisma ORM, and PostgreSQL. Seven security mechanisms are implemented: JWT HS256 authentication with first-login enforcement, deterministic AES-256-ECB encryption for sensitive patient identity fields, role-based access control, multi-tenant data isolation, append-only audit logging, rate limiting, and SHA-256-based digital signatures for clinical reports. Testing through eight security threat scenarios demonstrated that all defense mechanisms function as expected. Performance overhead remains within acceptable tolerance, with a 33.0% login response time increase as a deliberate consequence of the Bcrypt algorithm. The system demonstrates that layered security can be effectively implemented on a medical digital platform without significantly compromising service availability.

Keywords: Audit log, Authentication, Encryption, RBAC, Security, Tuberculosis

PENDAHULUAN

Tuberkulosis (TBC) merupakan penyakit infeksi yang disebabkan oleh bakteri *Mycobacterium tuberculosis* dan masih menjadi beban kesehatan global yang kritis. WHO melaporkan bahwa jumlah orang yang baru terdiagnosis dan dilaporkan sebagai kasus TBC secara global mencapai 7,5 juta pada tahun 2022. Pada tahun yang sama, Indonesia menjadi negara dengan kontribusi kasus TBC terbesar kedua setelah India, yaitu sekitar 10% dari total kasus global (WHO 2023). Secara nasional, WHO memperkirakan 387 per 100.000 penduduk Indonesia terkena TBC pada tahun 2023, setara dengan lebih dari 1,09 juta kasus, dengan angka kematian mencapai 130.927 jiwa (WHO 2026). Studi yang diterbitkan di *The Lancet Respiratory Medicine* mengungkap bahwa antara 2015 dan 2023 estimasi insiden TBC di

¹Program Studi Ilmu Komputer, Sekolah Sains Data, Matematika, dan Informatika, Institut Pertanian Bogor, Bogor 16680

²Program Studi Ilmu Komputer, Sekolah Sains Data, Matematika, dan Informatika, Institut Pertanian Bogor, Bogor 16680

³Program Studi Ilmu Komputer, Sekolah Sains Data, Matematika, dan Informatika, Institut Pertanian Bogor, Bogor 16680

*Penulis Korespondensi: Tel/Faks: 0895630476317 ; Surel: cokgdsatria@apps.ipb.ac.id

Indonesia meningkat sebesar 19% dan kematian meningkat 26%, yang menunjukkan bahwa pengendalian TBC di Indonesia masih menghadapi tantangan besar, terutama dalam menutup kesenjangan antara estimasi kasus dan kasus yang dilaporkan (Saktiawati dan Probandari 2025). Salah satu hambatan utama adalah diagnosis histopatologi TBC yang masih bergantung pada identifikasi manual struktur seluler khas oleh dokter patologi, sementara digitalisasi proses ini ke dalam sistem berbasis web menuntut perlindungan data sensitif seperti data pasien, citra histopatologi, hasil analisis AI, dan keputusan klinis agar tetap terjaga kerahasiaan, integritas, dan ketersediaannya.

Upaya mengotomasi analisis citra medis untuk deteksi TBC telah menjadi fokus berbagai penelitian. Tinjauan sistematis yang dipublikasikan di *Journal of Medical Internet Research* oleh Hansun et al. menunjukkan bahwa model *machine learning* dan *deep learning* untuk deteksi TBC menggunakan *chest x-ray* memiliki potensi diagnostik yang tinggi, dengan rerata sensitivitas sebesar 90,15% dan spesifisitas sebesar 89,31%, serta hasil meta-analisis pada 10 studi berupa *pooled sensitivity* 0,9857 dan *pooled specificity* 0,9805. Namun, Hansun et al. juga mencatat bahwa sebagian besar penelitian masih berfokus pada pengembangan model, dan hanya dua studi yang melaporkan aplikasi atau prototipe berjalan, sehingga implementasi praktisnya masih terbatas (Hansun et al. 2023). Kondisi ini menunjukkan bahwa tantangan utama tidak hanya terletak pada akurasi model AI, tetapi juga pada kebutuhan sistem deteksi TBC berbasis web yang mampu mengintegrasikan inferensi AI dengan keputusan klinis dokter secara terstruktur, terdokumentasi, dan aman melalui perlindungan akses, penyimpanan data, serta pertukaran informasi medis.

Pendekatan *human-in-the-loop* (HITL), yaitu paradigma kolaborasi antara AI dan keahlian manusia dalam pengambilan keputusan, telah diidentifikasi sebagai solusi yang tepat untuk konteks klinis berisiko tinggi. Olawade et al. dalam tinjauan naratif komprehensif yang diterbitkan di *International Journal of Medical Informatics* menunjukkan bahwa penerapan AI berbasis *human-in-the-loop* (HITL) dalam layanan kesehatan dapat memberikan keunggulan dibandingkan pendekatan AI sepenuhnya otomatis maupun pendekatan klinisi tanpa bantuan AI, terutama dalam peningkatan akurasi diagnostik, pengurangan kesalahan medis, peningkatan keselamatan pasien, serta peningkatan kepercayaan tenaga kesehatan terhadap sistem (Olawade et al. 2026). Namun, keberhasilan HITL pada sistem klinis berbasis web dan REST API juga bergantung pada rancangan keamanan yang mampu mencegah akses tidak sah terhadap data pasien, kasus, citra, dan hasil validasi, sekaligus menyediakan *audit trail* serta mekanisme integritas seperti tanda tangan digital agar aktivitas pengguna dan laporan akhir dapat ditelusuri, diverifikasi, dan tidak mudah disangkal.

Berdasarkan kerangka tersebut, penelitian ini bertujuan merancang dan mengimplementasikan sistem deteksi TBC berbasis web yang mengintegrasikan manajemen kasus klinis, unggah dan analisis citra histopatologi berbasis AI, serta validasi dokter patologi dalam satu platform digital terpadu yang memperhatikan aspek keamanan informasi. Sistem dibangun dengan antarmuka React 19 dan TypeScript, serta backend Express.js v5, Prisma ORM, dan PostgreSQL dengan pendekatan HITL, di mana AI membantu analisis awal, sedangkan keputusan akhir tetap berada pada dokter patologi. Selain mendukung percepatan diagnosis TBC dan pencatatan digital, sistem ini dirancang untuk memperkuat pengamanan akses, perlindungan data sensitif pasien, keterlacakan aktivitas pengguna, serta integritas hasil pemeriksaan dan laporan klinis. Dengan demikian, penelitian ini diharapkan berkontribusi pada pengembangan sistem pendukung diagnosis TBC yang tidak hanya berfokus pada performa AI, tetapi juga pada keamanan, akuntabilitas, dan keandalan alur kerja klinis digital di fasilitas kesehatan Indonesia.

METODE

Penelitian ini menggunakan pendekatan design science research untuk menghasilkan artefak berupa backend sistem manajemen laboratorium TBC dengan arsitektur keamanan berlapis. Desain keamanan mengacu pada model CIA Triad (Confidentiality, Integrity,

Availability) dan OWASP API Security Top 10 sebagai kerangka acuan ancaman yang relevan dengan sistem informasi medis berbasis web.

Perancangan Arsitektur Sistem

Sistem dibangun mengikuti pola arsitektur berlapis (layered architecture): lapisan routes mendefinisikan titik masuk API, lapisan middleware menangani validasi input dan kontrol akses, lapisan controller mengurai permintaan HTTP, lapisan service menjalankan seluruh logika bisnis dan keamanan domain, serta lapisan database dikelola melalui Prisma ORM dengan PostgreSQL. Setiap mekanisme keamanan diimplementasikan sebagai modul terpisah sesuai prinsip separation of concerns agar dapat diaudit dan diuji secara independen. Penyimpanan berkas citra histopatologi dan laporan klinis menggunakan Supabase Object Storage dengan akses berbasis presigned URL berumur pendek untuk membatasi paparan tautan.

Pemilihan setiap mekanisme keamanan didasarkan pada pemetaan ancaman spesifik: bocornya data identitas pasien ditangani dengan enkripsi AES-256-ECB deterministik pada kolom NIK dan nomor BPJS; pengambilalihan akun diatasi dengan Bcrypt (cost factor 10) dan kebijakan first-login enforcement; eskalasi wewenang dicegah melalui RBAC middleware berbasis JWT; tumpang-tindih data antar institusi diblokir oleh fungsi assertSameInstitution(); pemalsuan rekam jejak klinis dimitigasi dengan audit log append-only; serta serangan DDoS dibatasi oleh rate limiter pada seluruh gerbang API. Integritas laporan klinis dijamin melalui tanda tangan digital SHA-256 yang mengikat isi snapshot, identitas penandatanganan, waktu, dan ID laporan.

Pengujian Keamanan dan Pengukuran Kinerja

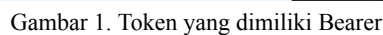
Evaluasi efektivitas dilakukan melalui pengujian keamanan berbasis skenario (scenario-based security testing) dengan delapan kasus uji yang merepresentasikan vektor ancaman utama. Setiap skenario mendefinisikan kondisi payload anomali, ekspektasi kode respons HTTP, dan kriteria keberhasilan yang terukur secara objektif. Skenario mencakup: akses tanpa token (TC-01), token kedaluwarsa (TC-02), injeksi SQL pada form autentikasi (TC-03), serangan brute-force berulang (TC-04), pelanggaran wewenang RBAC (TC-05), pelanggaran isolasi data institusi (TC-06), bypass validasi Zod (TC-07), dan akses storage dengan signed URL kedaluwarsa (TC-08).

Pengukuran dampak kinerja dilakukan dengan membandingkan waktu respons dan konsumsi memori server sebelum dan sesudah implementasi lapisan keamanan pada lingkungan pengembangan lokal menggunakan alat ukur benchmark berbasis Node.js. Metrik yang diukur meliputi response time operasi login, response time operasi baca data, dan konsumsi memory heap server.

HASIL DAN PEMBAHASAN

Implementasi Autentikasi dan Perlindungan Kredensial (Authentication)

Implementasi mekanisme autentikasi pengguna pada arsitektur backend dibangun dengan mengedepankan keamanan berbasis token dan perlindungan kredensial berlapis. Pengelolaan sesi diimplementasikan menggunakan JSON Web Token (JWT) dengan algoritma enkripsi HS256. Untuk meminimalkan risiko pembajakan sesi, token dirancang dengan batasan masa kedaluwarsa selama 24 jam (1 hari), sehingga memastikan bahwa akses pengguna yang tertinggal atau tidak aktif akan diputus secara otomatis oleh sistem.



Update Your Credentials

Protect your account by creating a new, personalized password for your profile

Security Action Required: Your current password was generated by an administrator. For your protection, please update it immediately.

EMAIL

operator@rumahsakit.com

CURRENT PASSWORD

Password

NEW PASSWORD

Password

CONFIRM NEW PASSWORD

Confirm Password

password_hash	text	role	Role
\$2b\$10\$3vnK0Jk3LyDaO.zhrU6lR.Hx5VQmUOJfpjaJlLd4hW5kXU88aDtOG		ADMIN_AI	
\$2b\$10\$3vnK0Jk3LyDaO.zhrU6lR.Hx5VQmUOJfpjaJlLd4hW5kXU88aDtOG		DOKTER_PATOLOGI	
\$2b\$10\$3vnK0Jk3LyDaO.zhrU6lR.Hx5VQmUOJfpjaJlLd4hW5kXU88aDtOG		DOKTER_PATOLOGI	
\$2b\$10\$3vnK0Jk3LyDaO.zhrU6lR.Hx5VQmUOJfpjaJlLd4hW5kXU88aDtOG		OPERATOR_LAB	

Implementasi Otorisasi dan Isolasi Data Institusi (*Authorization*)

Sistem mengimplementasi penerapan hak akses berbasis peran yang mengklasifikasikan pengguna ke dalam tiga entitas utama, yakni Teknisi Lab, Dokter Patologi, dan Admin AI. Pengamanan pada setiap titik akhir API ditegakkan melalui perangkat lunak *middleware* khusus, seperti modul autentikasi dan utilitas akses. Komponen ini bertugas memverifikasi keabsahan token sesi sekaligus memastikan kecocokan hak akses pengguna dengan operasi yang diminta, sehingga serangan eskalasi privilege dapat dicegah secara efektif.

Tabel 1. Matriks Akses RBAC

No	Endpoint API	Metode HTTP	Teknisi Lab	Dokter Patologi	Admin AI	Deskripsi Tindakan yang Diizinkan
1	/api/auth/login	POST	Ya	Ya	Ya	Melakukan autentikasi kredensial dan menerbitkan token JWT.
2	/api/auth/update-credentials	POST	Ya	Ya	Ya	Memperbarui kata sandi (memenuhi kebijakan login pertama).
3	/api/patients	POST	Ya	-	-	Mendaftarkan data rekam medis pasien baru (terenkripsi AES-256).
4	/api/patients/:id	GET	Ya	Ya	-	Membaca profil pasien (dibatasi oleh fungsi isolasi institusi).
5	/api/cases	POST	Ya	-	-	Membuat kasus rekam medis baru dan mengunggah citra histopatologi.
6	/api/cases/:id	GET	Ya	Ya	-	Membaca detail kasus dan mendapatkan tautan akses (presigned URL) citra.
7	/api/validations	POST	-	Ya	-	Memberikan diagnosis klinis dan memvalidasi hasil deteksi AI.
8	/api/reports	POST	-	-	Ya	Membuat laporan klinis dengan tanda tangan digital

						SHA-256 secara otomatis.
9	/api/reports/:id	GET	-	-	Ya	Mengunduh snapshot laporan klinis berserta tautan akses ke cloud storage.

Sebagai pelengkap pengamanan berbasis peran, sistem turut mengimplementasikan fitur isolasi data menggunakan fungsi validasi institusi. Fungsi tersebut berperan sebagai gerbang logika yang secara ketat membatasi visibilitas dan interaksi data antar fasilitas kesehatan. Melalui mekanisme ini, pengguna dari satu instansi laboratorium atau rumah sakit dipastikan tidak dapat melihat, memodifikasi, maupun menghapus rekam medis milik institusi lain, terlepas dari kesetaraan tingkat kewenangan peran yang mereka miliki.

```
export const assertSameInstitution = async (userAId: string, userBId: string) => {
  const [userA, userB] = await Promise.all([
    prisma.user.findUnique({ where: { id: userAId }, select: { institution: true } }),
    prisma.user.findUnique({ where: { id: userBId }, select: { institution: true } }),
  ]);

  if (!userA?.institution || !userB?.institution) {
    throw new AppError("Akses ditolak: institusi tidak terdaftar", 403);
  }

  if (userA.institution !== userB.institution) {
    throw new AppError("Akses ditolak: resource milik institusi lain", 403);
  }
};
```

Gambar 4. Logika fungsi assertSameInstitution() untuk validasi ID institusi

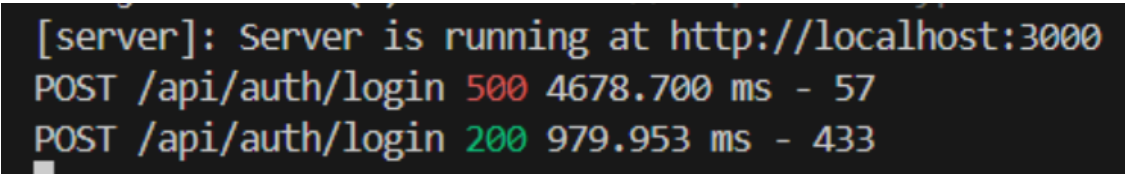
Implementasi Akuntabilitas dan Log Audit Backend (*Accountability*)

Untuk menjamin aspek *non-repudiation* di dalam sistem, pelacakan rekam jejak aktivitas pengguna menjadi komponen pengamanan yang sangat kritis. Sistem ini menerapkan log audit berkonsep *append-only*, di mana modul pencatatan bertugas menyimpan setiap riwayat manipulasi data sensitif seperti pembuatan profil pasien atau penetapan hasil diagnosis medis. Desain *append-only* ini mengunci data historis agar tidak dapat dimodifikasi maupun dihapus oleh pihak mana pun, termasuk administrator tingkat tinggi. Hal ini memastikan bahwa jika terjadi perselisihan atau penyalahgunaan akses, sistem memiliki bukti otentik yang mengikat secara definitif antara identitas pengguna dengan tindakan spesifiknya, sehingga pelaku tidak dapat menyangkal perbuatan tersebut.

id	user_id	action	entity_id	entity_type	payload	created_at
0006185c-4635-4a44-a7d9-0d270a8987f1	865b815e-3b3e-4c2b-b578-8cdee...	SUBMIT_VALIDATION	96643f6c-433e-43a6-8e43-9e8cbbd576c	Validation	["image_id": "e1acd0a6-a09d-453e-8b6f-5...	2026-06-11 08:34:12.448
00071499-930d-4362-8422-ec97338da7	c10af8bf-9e6c-4a77-8851-f75628f...	CREATE_PATIENT	7fb698c7-6400-4a23-9b94-1844d35afe5	Patient	NULL	2026-06-14 07:11:57.001
060d34a6-dbf7-4db8-8e75-10a10e6f6a63	38439f88-72c1-4419-a875-83823d...	SUBMIT_VALIDATION	4d45c9f6-fca2-4746-bdb6-a18f223a6982	Validation	["image_id": "a4429d13-0cb5-4c2e-8dd1-f...	2026-06-11 05:37:44.008
07b684cd-6a9e-48d9-950f-d33f9d21d7e1	38439f88-72c1-4419-a875-83823d...	SUBMIT_VALIDATION	d481ab78-cd89-4627-89b4-e8a33aceb85	Validation	["image_id": "c7d6b403-7a2e-4c91-aed1-d...	2026-06-12 04:53:43.745
0a8f5033-a109-42aa-ba99-41be08a6ceff	c10af8bf-9e6c-4a77-8851-f75628f...	SUBMIT_CASE	28d45461-bec8-472a-a03e-91f96e8c2a86	Case	NULL	2026-06-12 17:19:22.339
0a8f5033-a109-42aa-ba99-41be08a6ceff	c10af8bf-9e6c-4a77-8851-f75628f...	DELETE_IMAGE	d2fda382-a8e1-4396-9961-a8e02d2729	Image	NULL	2026-06-14 07:14:18.245
0b88cd5e-853c-433b-bf95-388ce2cf9b2d	c10af8bf-9e6c-4a77-8851-f75628f...	CREATE_CASE	53e48256-793c-4c1c-b413-e8036d88bd0	Case	NULL	2026-06-12 05:02:51.78
1382931e-3176-4da2-b6c7-955d3b417f8f	38439f88-72c1-4419-a875-83823d...	SUBMIT_VALIDATION	d481ab78-cd89-4627-89b4-e8a33aceb85	Validation	["image_id": "c7d6b403-7a2e-4c91-aed1-d...	2026-06-09 16:34:10.973

Gambar 5. Catatan baris data log audit mentah dari database

Selain pencatatan aktivitas tingkat aplikasi, transparansi operasional juga diterapkan pada lapisan komunikasi jaringan menggunakan middleware Morgan Logger. Modul ini berjalan di latar belakang untuk merekam secara otomatis seluruh permintaan HTTP yang masuk ke server. Detail yang dicatat mencakup rute API, metode HTTP, waktu eksekusi, serta kode status respons. Pemantauan lalu lintas jaringan ini berfungsi sebagai lapisan pertahanan analitik yang krusial. Catatan log tersebut memberikan informasi langsung bagi administrator untuk mendeteksi anomali akses, mengidentifikasi upaya pemindaian kerentanan dari pihak luar, dan memfasilitasi investigasi forensik apabila terjadi insiden keamanan.



```
[server]: Server is running at http://localhost:3000
POST /api/auth/login 500 4678.700 ms - 57
POST /api/auth/login 200 979.953 ms - 433
```

Gambar 6. Catatan baris data log audit mentah dari database

Hasil Pengujian Kasus Keamanan

Efektivitas sistem keamanan dibuktikan secara empiris melalui serangkaian pengujian yang komprehensif. Pengujian ini didasarkan pada delapan skenario ancaman utama untuk mengevaluasi ketahanan API (*Application Programming Interface*) terhadap berbagai vektor serangan. Dalam setiap skenarionya, sistem diuji menggunakan muatan (*payload*) anomali, seperti simulasi penggunaan sesi autentikasi yang tidak valid, manipulasi token, hingga percobaan pelanggaran batas wewenang antarperan (*privilege escalation*). Keberhasilan pertahanan sistem diukur secara objektif berdasarkan kode status HTTP yang dikembalikan oleh server. Hasil pengujian menunjukkan bahwa *middleware* keamanan berhasil mendeteksi dan memblokir seluruh permintaan (*request*) tidak sah tersebut sebelum permintaan itu mencapai logika utama aplikasi (*core business logic*).

Tabel 2. Hasil Uji Kasus Keamanan

No	Deskripsi Skenario	Payload Input / Kondisi Uji	Ekspektasi (Kode HTTP)	Aktual (Kode HTTP)	Kesimpulan
TC-01	Akses rute tertutup tanpa menyertakan token sesi	Memanggil titik akhir API dengan header Authorization: null	401 Unauthorized	401	Lulus
TC-02	Akses rute dengan token JWT yang sudah kedaluwarsa	Menggunakan token sesi yang berumur lebih dari batas waktu 24 jam	401 Unauthorized	401	Lulus
TC-03	Injeksi parameter berbahaya pada form autentikasi (SQL Injection)	Pengiriman payload anomali: email: "admin' OR 1=1 --"	401 Unauthorized	401	Lulus
TC-04	Percobaan brute-force atau serangan spam request pada rute Login	Pengiriman lebih dari 100 request beruntun dalam rentang kurang dari 15 menit	429 Too Many Requests	429	Lulus

TC-05	Pelanggaran batas wewenang (RBAC) pada titik akhir spesifik	Pemanggilan rute GET /api/review/queue menggunakan token milik Teknisi Lab	403 Forbidden	403	Lulus
TC-06	Pelanggaran isolasi data institusi (Upaya peretasan lintas rumah sakit)	Pemanggilan profil Pasien dari institusi A menggunakan token dari institusi B	403 Forbidden	403	Lulus
TC-07	Melewati lapisan validasi tipe data (Zod) dengan data manipulasi	Pemanggilan metode POST untuk pembuatan pasien tanpa menyertakan atribut no_induk	400 Bad Request	400	Lulus
TC-08	Meminta akses fail citra histopatologi dengan tautan yang kedaluwarsa	Tautan pra-tanda-tangan (Signed URL) diakses setelah melewati rentang 15 menit	403 Forbidden	403	Lulus

Dua mekanisme pertahanan utama yang dievaluasi secara khusus dalam pengujian ini adalah pembatasan laju permintaan (*rate limiting*) dan otorisasi berbasis peran (RBAC). Pada pengujian *rate limiting*, sistem diberikan beban permintaan yang tinggi dalam waktu singkat untuk menyimulasikan serangan *Denial-of-Service* (DoS). Sistem merespons dengan tepat dengan memblokir alamat IP penyerang dan mengembalikan kode status HTTP 429 (*Too Many Requests*). Selanjutnya, pada pengujian otorisasi, dilakukan simulasi eskalasi hak akses (*privilege escalation*) di mana kredensial akun Teknisi Lab digunakan untuk mencoba mengakses *endpoint* diagnostik klinis. *Middleware* keamanan berhasil mengintersepsi dan memblokir upaya tersebut dengan mengembalikan kode status HTTP 403 (*Forbidden*). Hasil ini mengonfirmasi bahwa mekanisme isolasi hak akses antarperan telah berfungsi secara optimal.

Analisis Dampak Keamanan Terhadap Kinerja Sistem

Evaluasi kinerja sistem menunjukkan adanya *overhead* yang terukur akibat penambahan lapisan keamanan pada arsitektur *backend*. Berdasarkan hasil pengujian, tercatat peningkatan waktu respons (*Response Time*) pada proses autentikasi (*login*) sebesar 72,4 ms, yaitu dari 219,4 ms menjadi 291,8 ms. Peningkatan latensi ini bukanlah sebuah degradasi performa, melainkan *trade-off* keamanan yang disengaja. Hal ini merupakan konsekuensi langsung dari penggunaan algoritma *hashing* Bcrypt dengan *cost factor* 10, yang memang dirancang untuk membutuhkan komputasi CPU intensif secara sengaja. Waktu komputasi ekstra ini diterapkan sebagai mekanisme pertahanan kriptografis untuk secara efektif memperlambat ancaman serangan *brute-force* terhadap kredensial pengguna.

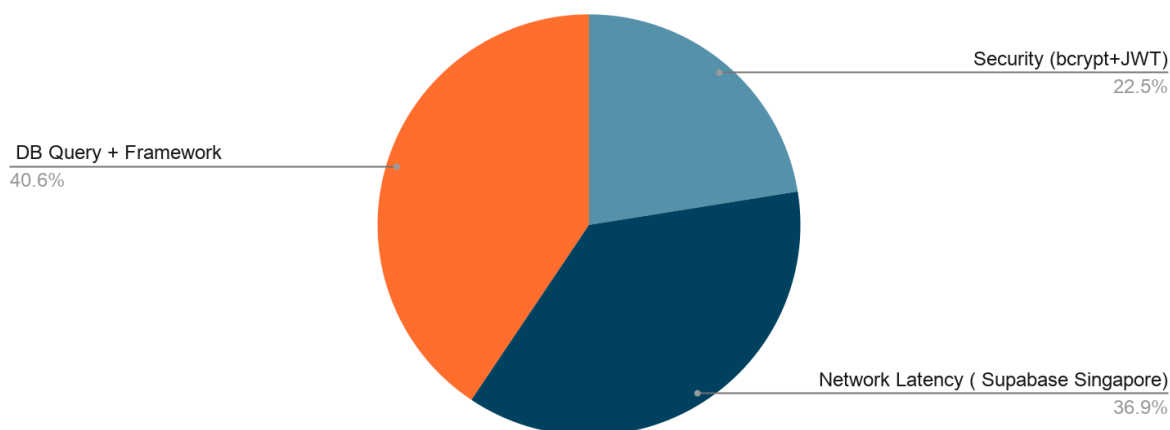
Tabel 3. Analisis perbandingan kinerja sistem dalam implementasi keamanan

Metrik	Sebelum	Sesudah	Δ	Δ (%)
Login RT	219.4 ms	291.8 ms	+72.4 ms	+33.0%
Get Data RT	0.8 ms	1.4 ms	+0.6 ms	+75.0%

Upload RT	N/A	N/A	N/A	N/A
CPU Load/Login	N/A	72 ms/op	+72ms	N/A
Memory Heap	6.6 MB	8.1 MB	+1.5 MB	+22.7%

Selain metrik waktu respons, implementasi fitur keamanan juga berdampak pada peningkatan penggunaan memori *heap* server sebesar 1,5 MB (dari 6,6 MB menjadi 8,1 MB). Peningkatan ini sepenuhnya dialokasikan untuk memuat berbagai *middleware* keamanan yang berjalan secara simultan, seperti *rate limiter*, modul verifikasi token JWT, dan pencatat *audit log*. Secara keseluruhan, akumulasi *overhead* performa yang dihasilkan tergolong sangat minimal. Beban komputasi tambahan ini masih berada di dalam batas toleransi sistem yang aman, membuktikan bahwa tingkat keamanan yang tinggi dapat dicapai tanpa mengorbankan efisiensi layanan platform medis.

Benchmarking (Total Time: 325ms)



CIA Triad dan *Threat Mitigation*

Evaluasi terhadap arsitektur sistem menunjukkan bahwa desain teknis yang diimplementasikan telah memenuhi pilar utama keamanan informasi. Pilar kerahasiaan (*Confidentiality*) diterapkan secara berlapis menggunakan enkripsi AES-256 *at-rest* pada seluruh data identitas sensitif untuk mencegah risiko kebocoran data pada tingkat database. Sementara itu, perlindungan untuk citra histopatologi dilakukan dengan mengisolasinya di dalam Object Storage, di mana akses eksternal hanya dapat dilakukan melalui *presigned URL* yang otomatis kadaluarsa dalam waktu 15 menit.

Tabel 4. Matriks Pemetaan Risiko dan Mitigasi Keamanan Sistem

No	Ancaman Awal	Fitur Keamanan	Mekanisme Teknis Pertahanan	Status Pemenuhan Pilar CIA
1	Kebocoran data identitas pasien akibat penetrasi basis data langsung	Enkripsi At-Rest Tingkat Kolom	Enkripsi deterministik menggunakan algoritma AES-256 pada atribut NIK dan nomor BPJS	Confidentiality

2	Pencurian akses dokumen dan citra medis melalui pembagian tautan (URL Sharing)	Penyimpanan Awan Privat	Akses keluar wajib menggunakan tautan pra-tanda-tangan (Presigned URL) dengan durasi hidup maksimal 15 menit	Confidentiality
3	Pengambilalihan akun secara paksa menggunakan metode Brute-force / Credential Stuffing	Kriptografi Kredensial Lanjutan	Proses hashing menggunakan Bcrypt (Cost Factor 10) serta penegakan kebijakan ganti kata sandi wajib pada first-login	Confidentiality
4	Eskalasi wewenang oleh pengguna tingkat rendah untuk memanipulasi diagnosis	Kontrol Akses Berbasis Peran (RBAC)	Intersepsi middleware pada titik akhir antarmuka (API) untuk memvalidasi JWT spesifik berdasarkan tingkat kepangkatan (Role)	Confidentiality & Integrity
5	Tumpang tindih dan manipulasi rekam medis antar institusi kesehatan berbeda	Isolasi Data Multitenant	Pencegahan akses silang melalui pengecekan level logika bisnis menggunakan fungsi <code>assertSameInstitution()</code>	Confidentiality & Integrity
6	Manipulasi diam-diam, penghapusan, atau penyangkalan atas perubahan rekam klinis	Sistem Perekaman Jejak (Traceability)	Perekaman mutasi data otomatis dalam Audit Log bersistem hanya-tambah (Append-Only) di basis data	Integrity & Non-Repudiation
7	Kelumpuhan peladen akibat hantaman lalu lintas spam atau serangan Denial of Service	Pembatasan Lalu Lintas Jaringan	Pemasangan middleware Rate Limiter pada seluruh gerbang antarmuka pemrograman untuk membatasi frekuensi request berlebih	Availability

Pemenuhan pilar integritas (*Integrity*) pada sistem dicapai melalui penerapan *audit log* yang bersifat *append-only*. Mekanisme ini memastikan setiap jejak perubahan data rekam medis tercatat secara historis dan tidak dapat dimodifikasi atau dihapus oleh pihak manapun, sehingga keaslian riwayat data tetap terjamin mutlak.

Sementara itu, pilar ketersediaan (*Availability*) dibuktikan dengan stabilitas server yang mampu mempertahankan waktu respons optimal tanpa degradasi performa yang signifikan, meskipun memproses komputasi enkripsi. Untuk menjamin kontinuitas layanan, sistem juga dilengkapi dengan *middleware rate limiter* yang berfungsi mencegah kelumpuhan server akibat lonjakan permintaan abnormal (*request flooding*). Hal ini memastikan infrastruktur aplikasi medis tetap stabil dan selalu dapat diakses saat dibutuhkan.

Evaluasi Batasan Sistem

Sebagai bentuk objektivitas dalam pengembangan, terdapat tiga batasan utama pada sistem yang berjalan saat ini. Pertama, fitur tanda tangan digital (*digital signature*) pada laporan klinis saat ini diimplementasikan menggunakan fungsi *hash* kriptografis SHA-256 yang mengikat isi *snapshot* laporan, identitas penandatanganan, waktu pembuatan, dan ID

laporan secara *tamper-evident*. Pendekatan ini sudah mampu mendeteksi perubahan isi laporan, namun bersifat simetris sehingga belum mendukung verifikasi oleh pihak ketiga secara independen. Pengembangan ke arah tanda tangan digital asimetris berbasis RSA-2048, yang strukturnya telah disiapkan pada basis data, menjadi rencana penyempurnaan berikutnya agar laporan dapat diverifikasi tanpa mengetahui kunci rahasia. Kedua, integrasi dengan model kecerdasan buatan (AI) belum berjalan secara langsung (*real-time*). Data hasil diagnosis AI yang muncul di aplikasi saat ini masih berupa data tiruan (*dummy data*) yang disuntikkan lewat proses *database seeding*, murni hanya untuk kebutuhan pengujian antarmuka sistem.

Batasan ketiga berkaitan dengan validitas pengujian performa. Metrik kinerja seperti waktu respons dan penggunaan memori yang dipaparkan sebelumnya masih terbatas pada hasil pengujian di lingkungan lokal (*development environment*). Sistem ini belum diuji ketahanannya secara menyeluruh pada infrastruktur tingkat produksi (*production*) skala besar, terutama saat harus menangani ribuan permintaan akses (*request*) secara bersamaan. Ketiga batasan ini menjadi catatan evaluasi yang penting untuk penyempurnaan dan pengembangan sistem pada penelitian selanjutnya.

SIMPULAN

Penelitian ini berhasil merancang dan mengimplementasikan arsitektur keamanan berlapis pada backend sistem manajemen laboratorium dan skrining awal Tuberkulosis berbasis web dengan pendekatan human-in-the-loop. Tujuh mekanisme keamanan: autentikasi JWT HS256 dengan first-login enforcement, enkripsi AES-256-ECB pada identitas pasien, kontrol akses berbasis peran, isolasi data antar institusi, audit log append-only, pembatasan laju akses, serta tanda tangan digital SHA-256 pada laporan klinis, telah terbukti memenuhi ketiga pilar CIA Triad. Pengujian melalui delapan skenario ancaman menunjukkan seluruh lapisan pertahanan mampu mendeteksi dan memblokir muatan berbahaya sebelum menyentuh logika operasi utama, dengan kode respons HTTP aktual yang konsisten dengan ekspektasi pada setiap kasus uji.

Analisis dampak kinerja membuktikan bahwa penebalan lapisan keamanan menimbulkan overhead yang masih berada dalam batas toleransi sistem, dengan kenaikan waktu respons login sebesar 33,0% sebagai konsekuensi terencana dari algoritma Bcrypt yang justru memperkuat ketahanan terhadap serangan pemecahan sandi. Dengan demikian, sistem ini menunjukkan bahwa keamanan informasi tingkat tinggi dapat diterapkan pada platform medis digital tanpa mengorbankan ketersediaan layanan secara signifikan. Penelitian selanjutnya diarahkan pada penguatan tanda tangan digital ke skema asimetris RSA-2048, integrasi model AI secara real-time, serta pengujian ketahanan pada infrastruktur produksi berskala besar.

DAFTAR PUSTAKA

Hansun S, Argha A, Liaw ST, Celler BG, Marks GB. 2023. Machine and deep learning for tuberculosis detection on chest X-rays: systematic literature review. *Journal of Medical Internet Research* [Internet]. [diunduh 2026 Jun 26];25. <https://doi.org/10.2196/43154>.

Olawade DB, Plabon SB, Ojo A, Ogunbona MA, Makanjuola BD, Olasilola OR. 2026. Human in the loop artificial intelligence in healthcare: applications, outcomes, and implementation challenges. *International Journal of Medical Informatics* [Internet]. [diunduh 2026 Jun 26];213:106362. <https://doi.org/10.1016/j.ijmedinf.2026.106362>.

Saktiawati AMI, Probandari A. 2025. Tuberculosis in Indonesia: challenges and future directions. *The Lancet Respiratory Medicine* [Internet]. [diunduh 2026 Jun 26];13(8):669-671. [https://doi.org/10.1016/S2213-2600\(25\)00168-7](https://doi.org/10.1016/S2213-2600(25)00168-7).

World Health Organization. 2023. Global tuberculosis report 2023. Geneva (CH): World Health Organization.

World Health Organization. 2026. Indonesia charts next phase of TB response through national programme review. WHO Indonesia [Internet]. 2026 Jan 8 [diunduh 2026 Jun 26]. <https://www.who.int/indonesia/news/detail/08-01-2026-indonesia-charts-next-phase-of-tb-response-through-national-programme-review>.